

SAMSUNG PRISM - PROJECT REVIEW

PRISM

Privacy-First AI Consent and Redaction Platform for Multimodal AI Data
Built for India's Digital Personal Data Protection Act, 2023 · Worklet 26TS12VITV · SRIB-PRISM Program

Review date: 3 September 2026

End-to-end video demo | Architecture: capture-to-storage and DSAR | AI models and services | Role flows | Tech stack | Glossary

What this review covers

1

End-to-end video demo

A live walk through one project: approval, consent, video upload, tracking, tagging, redaction, erasure.

2

Architecture - capture to storage

One diagram: a frame or clip from the shutter to its encrypted resting place, and every component it touches.

3

Architecture - DSAR

Kept separate on purpose: how a rights request is discovered, executed, signed and delivered.

4

AI models and services

The nine model families, the five stateless workers and the seven queue workers, and why each was chosen.

5

Role flows

Data principal, data owner, collection agent, DPO, data admin - the flowcharts from the repository.

6

Tech stack in one page

Frontends, backend, AI core, infrastructure, verification tooling.

7

Patentability

What in PRISM is candidate inventive matter, the closest prior art, and how a filing would proceed.

8

Glossary

Platform acronyms, DPDP Act vocabulary we use correctly, and the terms we use that are not DPDP terms.

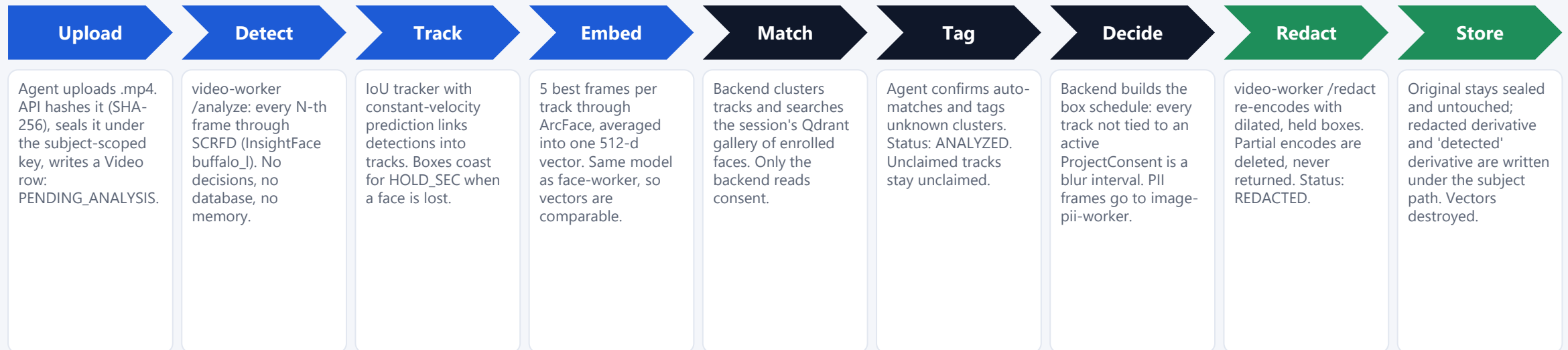
The demo script: one project, five roles, one clip, one erasure

Each step is a real screen in the running platform. The right column is what the reviewer should notice.

1	Data Owner	Create the project Purpose, retention, required data types (video + audio), consent template. Status stays DRAFT.	Nothing can be collected before governance.
2	DPO	Approve the project Project Approvals: review purpose limitation and the bound notice, approve. Policy version is frozen.	The DPO gate is a hard gate, not a checkbox.
3	Data Owner	Assign the agent My Projects > Assignments: the collection agent is scoped to this one project.	Agents only see projects they are assigned to.
4	Collection Agent	Open a session and share the invite New Session > QR / invite link for the data principal.	Every capture is tied to a session, an agent and a project.
5	Data Principal	Consent and enrol Read the notice, accept consent, enrol face (5 poses, 512-d ArcFace) and voice (192-d ECAPA).	Consent is per project and separately for biometrics.
6	Collection Agent	Upload the video Sessions > Upload: a short .mp4. The clip is sealed with AES-256-GCM before it touches disk.	The video worker detects and tracks faces; the PII worker scans frames.
7	Agent / Owner	Tag tracks and redact Session Video Panel: tracks matched to the enrolled person are confirmed; press Redact.	Every untagged track is blurred for the whole clip. Fail-closed: DEFERRED if a worker is down.
8	Data Principal	Raise erasure, confirm, download certificate Data Rights > Erasure. The principal sees what will be destroyed and presses Erase. Data Admin executes; DPO closes.	Ed25519-signed certificate lists every location purged, including the video derivatives.

What happens inside while the demo runs

Video is not 'many photos': a 2-minute 30 fps clip is 3,600 frames. Detection is strided, embedding is sparse, and the decision is never made by the worker.



Fail closed, in space and in time

Anything not affirmatively tagged is blurred. Tracks coast past their last detection and boxes are dilated, so a head turn never un-blurs a face for a quarter second inside a file stamped 'redacted'. A worker outage sets DEFERRED and blocks ingest instead of publishing a clean-looking clip.

Detect / Decide / Redact separation

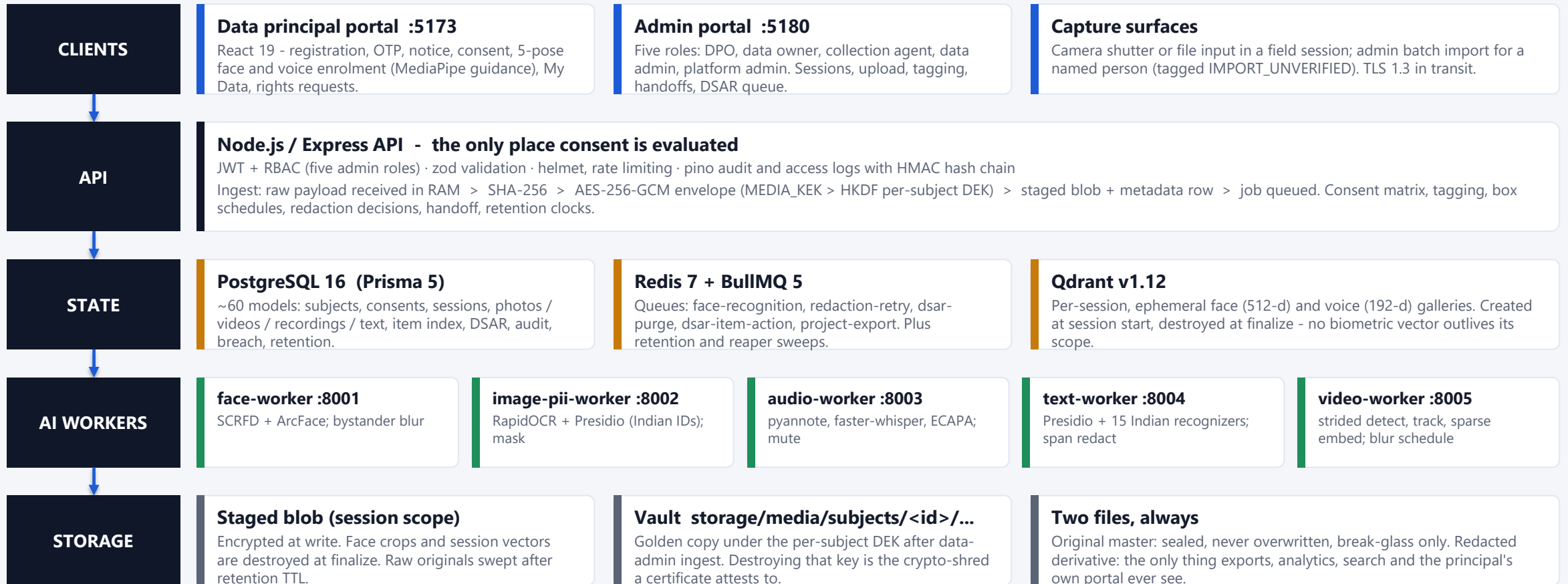
The worker reports what is in the frame and executes a rectangle list. Between those two calls a human tags, and the backend, the only component that reads the consent matrix, decides who may remain visible. A bug in an ML worker cannot expose an unconsented person.

One embedding space, enforced

video-worker loads the same buffalo_l pack as face-worker because the session gallery holds ArcFace vectors. A different model would compare by cosine similarity and produce confident nonsense. Averaging five views per track matches the gallery better than a single still does.

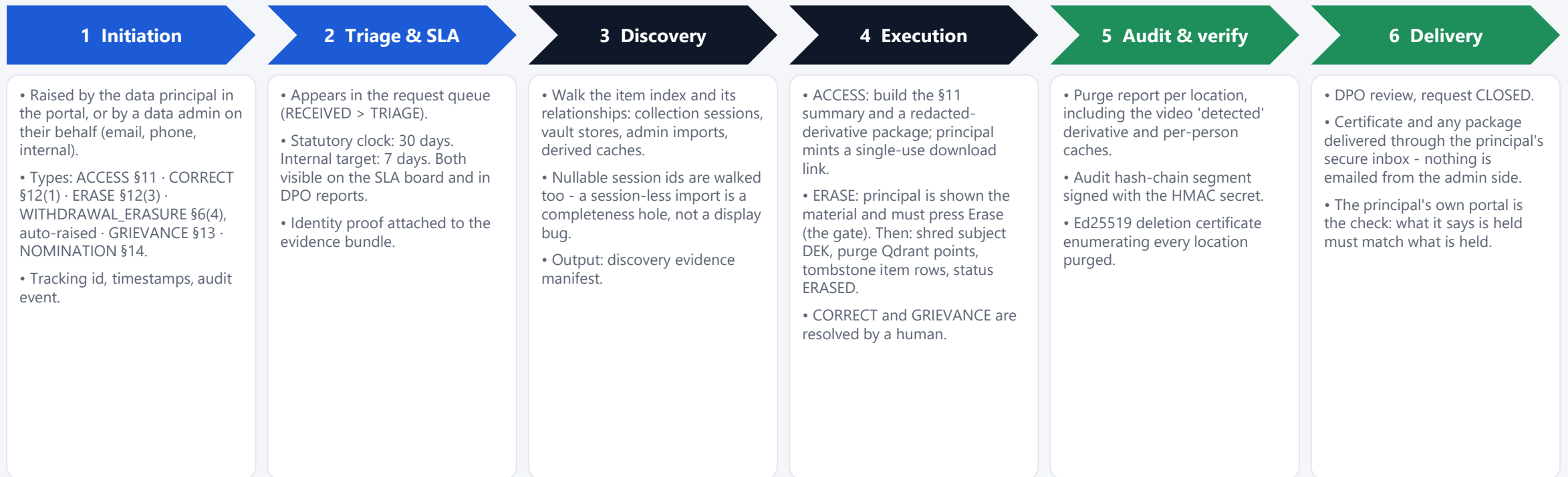
Capture to storage: one path for every modality

Every filesystem write goes through one module (storage.js), which is where envelope encryption lives. Workers hold no database access and no consent logic.



DSAR: a rights request from receipt to signed certificate

Separate from capture on purpose. Six phases, two execution branches, one clock that the law sets (30 days) and one we set ourselves (7 days).



Request lifecycle

RECEIVED > TRIAGE > DISCOVERY > EXECUTING > REVIEW > CLOSED (or REJECTED with a recorded reason)

Erasure cannot execute until the data principal has confirmed. Purge is a BullMQ job so a crash mid-way is retried, never half-done and silent.

Who does what

Data principal raises and confirms · DPO triages, sets SLA, approves closure · Data owner supplies project-scoped discovery evidence · Data admin executes export or purge · Platform admin holds break-glass only

Every read of an original along the way lands in the access log the principal can see.

Model summary: nine model families, all running locally on CPU

No third-party inference in the production redaction path. Every model executes inside the project's own containers.

Modality / worker	Model	Task	Why this one
Image · face-worker :8001	InsightFace buffalo_l (SCRFD detector + ArcFace, 512-d)	Face detection, embeddings for clustering, bystander blur	Best open accuracy/speed balance on CPU; batch pass after the session, so no GPU latency needed. Embeddings never persisted by the worker.
Image · image-pii-worker :8002	RapidOCR (ONNX)	Text extraction from photos and video frames	Weights ship inside the wheel: no download at build or run time, fully offline and reproducible.
Video · video-worker :8005	Presidio + spaCy en_core_web_sm + ~15 custom Indian recognizers	PII on OCR text: Aadhaar, PAN, GSTIN, Voter ID, passport, UPI, IFSC, plates	Stock Presidio has no Indian ID coverage. Fail-closed: any error returns 503, never 'no PII found'.
	InsightFace buffalo_l + IoU / constant-velocity tracker (non-ML)	Strided detection, cross-frame tracking, sparse per-track embedding	Forced compatibility: the gallery holds ArcFace vectors, so the same model is a correctness requirement. On-screen text is delegated to :8002.
	pyannote/speaker-diarization-3.1	Who spoke when	State-of-the-art open diarization; gated licence handled via HF token; lazy-loaded so /ready never blocks.
	faster-whisper (small, configurable)	Transcription with word timestamps	Size is a speed/accuracy dial. VAD filtering off so quiet bystander speech is never dropped before PII scan.
Audio · audio-worker :8003	SpeechBrain ECAPA-TDNN (spkrec-ecapa-voxceleb, 192-d)	Voice enrolment and speaker identity	~80 MB, open, accurate enough for consent matching; small cold start.
	Presidio (stock recognizers)	PII in transcripts	Spoken text does not need the document-ID recognizers; stock entity set suffices.
	Presidio + ~15 checksum-aware regex recognizers	PII spans with character offsets, consent-aware span redaction	Deliberately rule-based: deterministic and auditable. No model non-determinism in a compliance decision.
Text · text-worker :8004			
Browser · user portal	MediaPipe tasks-vision	Live guidance during 5-pose face capture	Runs in the browser; nothing leaves the device until the principal confirms the capture.

Demo-only, excluded from production: spaCy NER inside the Streamlit tool, and an OpenAI model for name disambiguation gated behind an API key. Reference-only code: ai-core/prism-visual-pipeline and ai-core/audio-services.

Services summary: how the AI side was built and how it is wired

Twelve workers in total: five Python FastAPI microservices and seven Node.js queue or timer workers, all behind one Express API.

One contract for every modality

CAPTURE > DETECT (AI worker: finds faces, PII, speech spans; makes no decision) > DECIDE (backend: consent + policy) > REDACT (AI worker executes an irreversible blur, mute or mask).

Every worker is stateless: no database, no consent logic, no memory between calls. Pydantic v2 + pydantic-settings, uvicorn, Python 3.10-3.12, uv for the audio services.

Image pipeline is queue-mediated (BullMQ). Audio, video and text redaction are synchronous HTTP calls from the backend.

Design principles observed across the code

No third-party inference in production. Detect / Decide / Redact separation. Fail closed: an outage is an explicit 503 or DEFERRED, never a clean scan.

Irreversible redaction: wide-kernel Gaussian and mosaic-then-blur, mute intervals, character masking, tuned to destroy signal rather than obscure it.

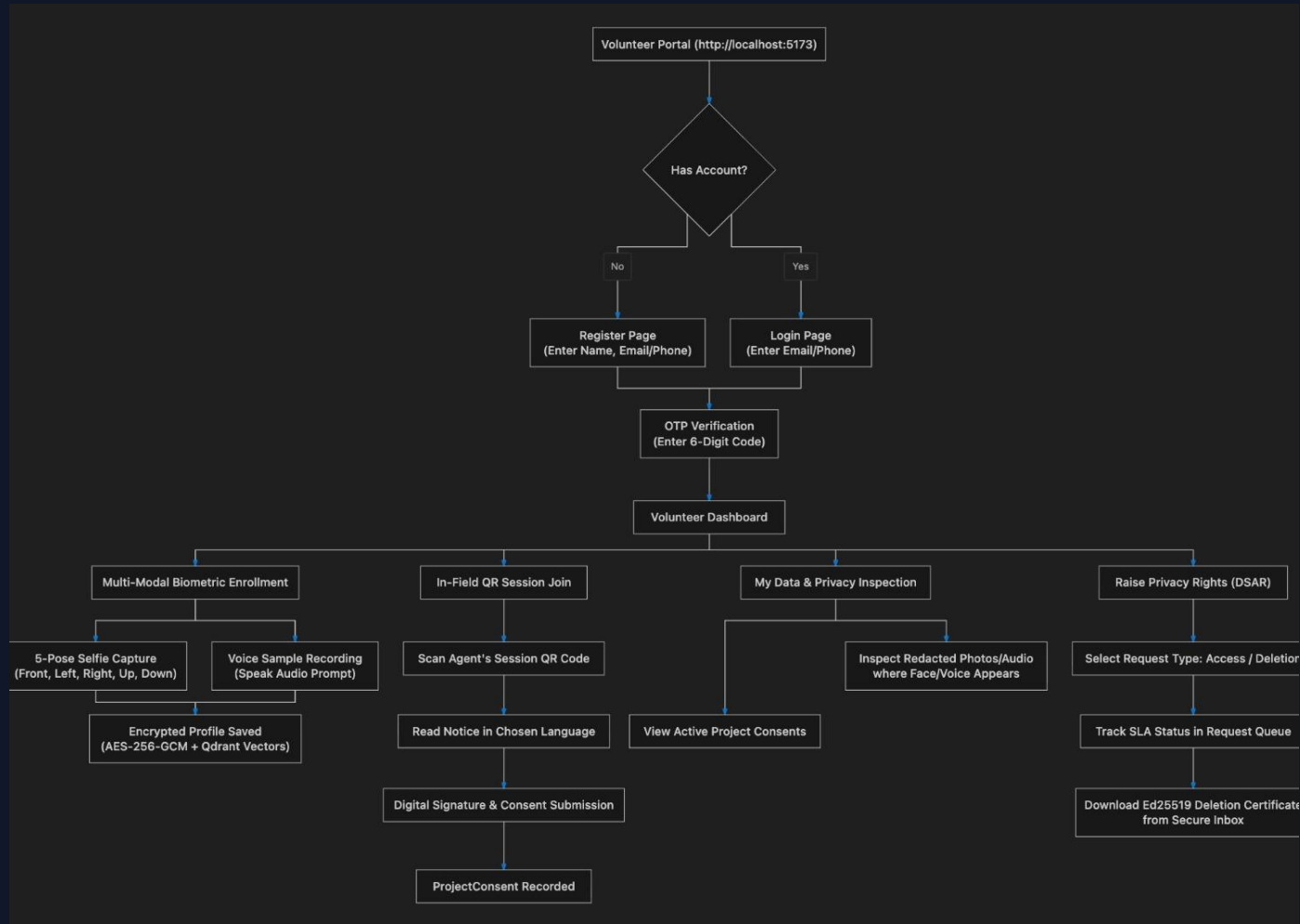
Shared embedding spaces enforced where two workers compare vectors. Data minimisation: session galleries and face crops are destroyed at finalize.

AI microservice	Port	Status	Role
face-worker	8001	core	Face detection, ArcFace embeddings, bystander blur
image-pii-worker	8002	core, not optional	OCR + Presidio masking; the image pipeline fails closed without it
audio-worker	8003	opt-in	Diarization, transcription, speaker ID, PII flags, mute redaction, voice embeddings
text-worker	8004	core	PII spans with offsets, consent-aware span redaction
video-worker	8005	opt-in	Detect, track, sparse embed; executes the blur box schedule

Backend worker (Node.js)	Trigger	Role
recognition.worker.js	queue: face-recognition	Face matching for a session against the Qdrant gallery once it ends
redaction.worker.js	queue: redaction-retry	Retries photos whose synchronous PII/face redaction failed
purge.worker.js	queue: dsar-purge	Executes erasure jobs and issues deletion certificates
itemAction.worker.js	queue: dsar-item-action	Per-item DSAR redact, delete or export-mark actions
export.worker.js	queue: project-export	Builds signed project export and DSAR access-package archives
retention.worker.js	interval sweep	Sweeps raw originals past TTL; expires download packages
reaper.worker.js	interval sweep	Requeues stalled photo/video jobs; times out stuck recognition

Data principal: register, consent, enrol, inspect, exercise rights

The person's own portal, built for a phone. Flow from the repository's flow folder.



Consent before anything

OTP sign-in, notice in the chosen language, digital signature. A ProjectConsent row is the key every later decision, and every erasure, hangs off.

Biometric enrolment is separate consent

Five poses and a voice sample, encrypted AES-256-GCM at rest, vectors in Qdrant. Withdrawal auto-raises an erasure request.

My Data is the \$11 surface

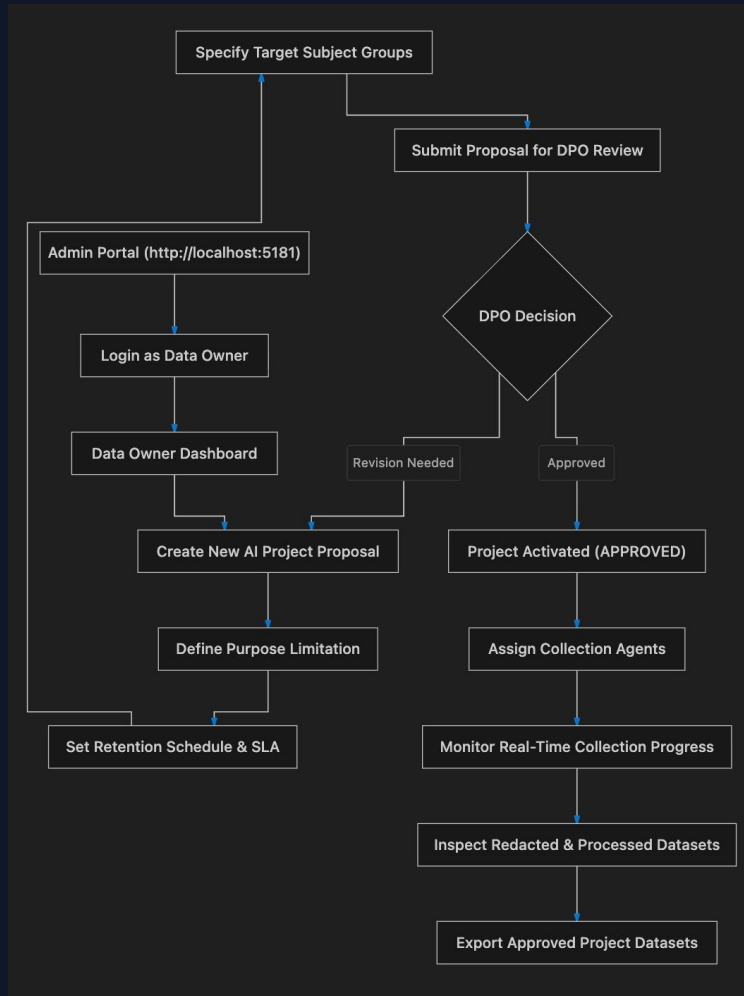
Redacted photos and audio where the face or voice appears, active consents, and every access to an original.

Rights requests

Access, correction, erasure, grievance, nomination. SLA status is visible, and the deletion certificate lands in the secure inbox.

Data owner: propose a purpose, get it approved, run the project

The business owner of a purpose. Cannot collect, only define, assign and inspect.



Purpose limitation is written down

Target groups, purpose, retention schedule and SLA are part of the proposal the DPO reviews. Rejection returns it with feedback.

Approval freezes policy

On APPROVED the policy version is frozen, so consent captured later is provably against the text that was approved.

Assign, then watch

Collection agents are assigned per project. Progress, processed datasets and redacted output are inspected here; originals are not.

Export

Approved datasets export as redacted derivatives with a signed manifest and EXIF/XMP provenance stamps on every image.

Collection agent: sessions, tagging, sealed handoff

The only human who sees raw frames, and only before archive. Everything is tied to a project, a session and consent.



Session QR joins consented people

The roster search shows everyone but offers Add on nobody who has not consented to this project.

Recognition is automatic, tagging is human

InsightFace vectors, Qdrant matching, people cards. The agent confirms matches and tags unidentified clusters.

Finalize re-checks consent

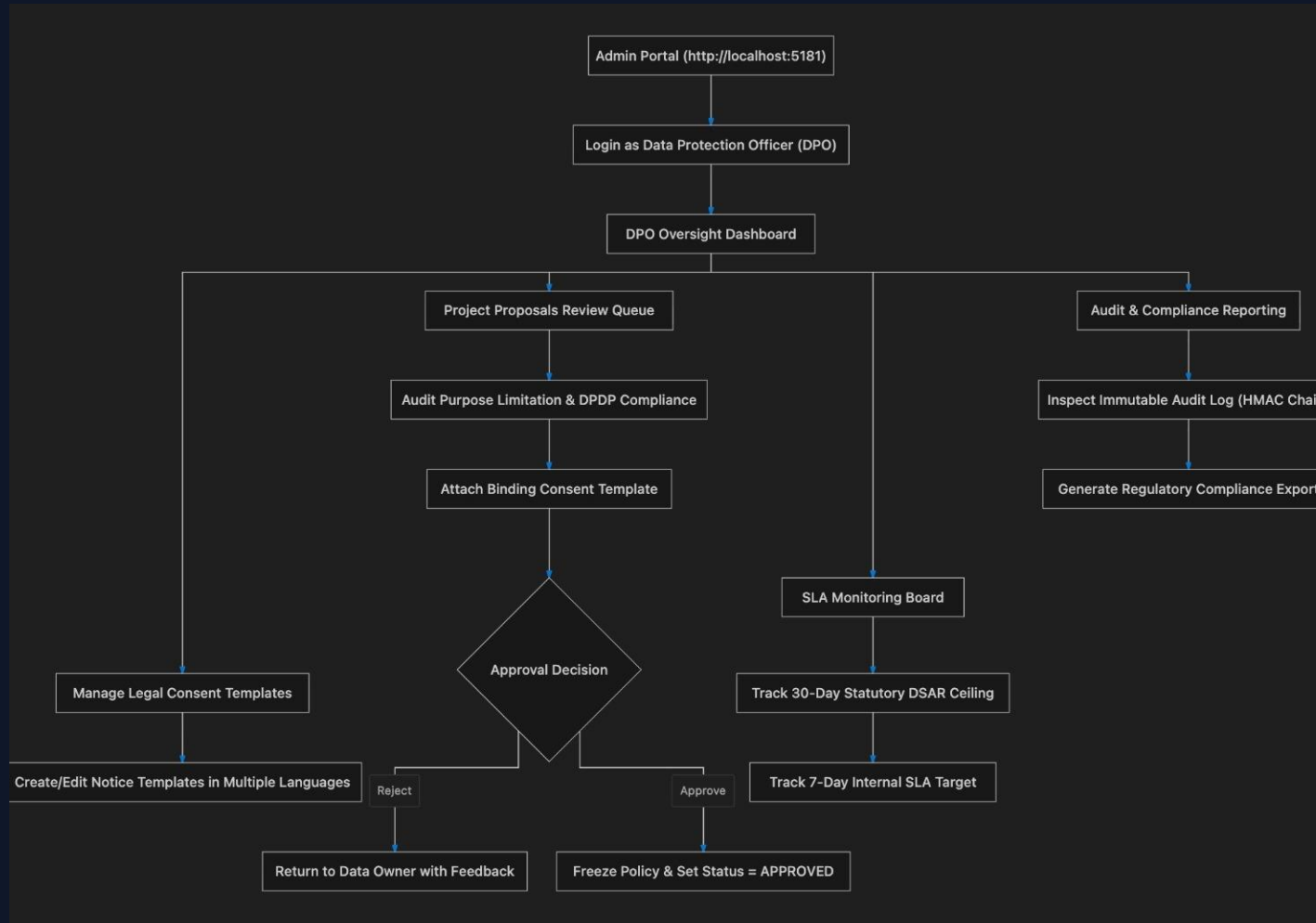
Revoked consents are dropped, bystander faces are blurred, document PII is masked, session vectors are destroyed.

Sealed handoff

The session is archived and sent for vault ingestion; the agent loses access to originals from here on.

DPO: govern, approve, monitor the clocks, report

Data Protection Officer under §10(2)(a). Owns the notice text, the approval gate and the compliance record.



Notice templates

Multi-language consent templates. A template cannot be published without a grievance contact (§5(1)(c), §13).

Approval gate

Audit purpose limitation and attach the binding template. Approve freezes policy; reject returns to the data owner with feedback.

Two clocks on one board

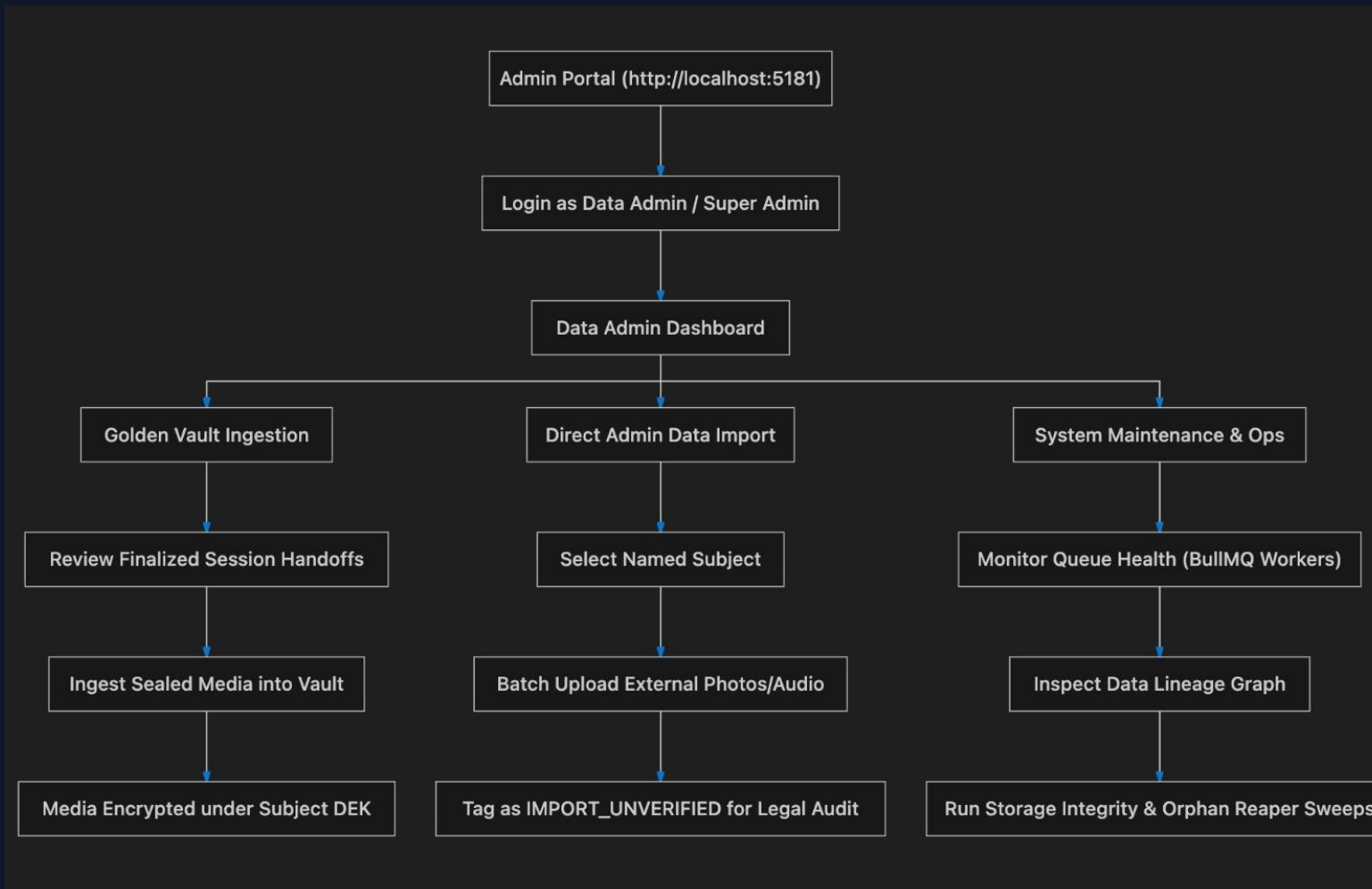
The 30-day statutory ceiling and the 7-day internal target for every open request.

Evidence a regulator would ask for

Immutable HMAC-chained audit log, breach records, and a compliance export for any period.

Data admin and platform admin: vault, imports, operations

The DSAR executor and the operator. Break-glass access is logged, never silent.



Golden vault ingestion

Finalized handoffs are reviewed and sealed into the vault under the subject's DEK; the retention clock starts.

Direct import is its own inbound edge

Files for a named person are PII-masked but not face-blurred (detection never ran) and tagged IMPORT_UNVERIFIED so a DSAR answer never presents them as consented collection.

Operations

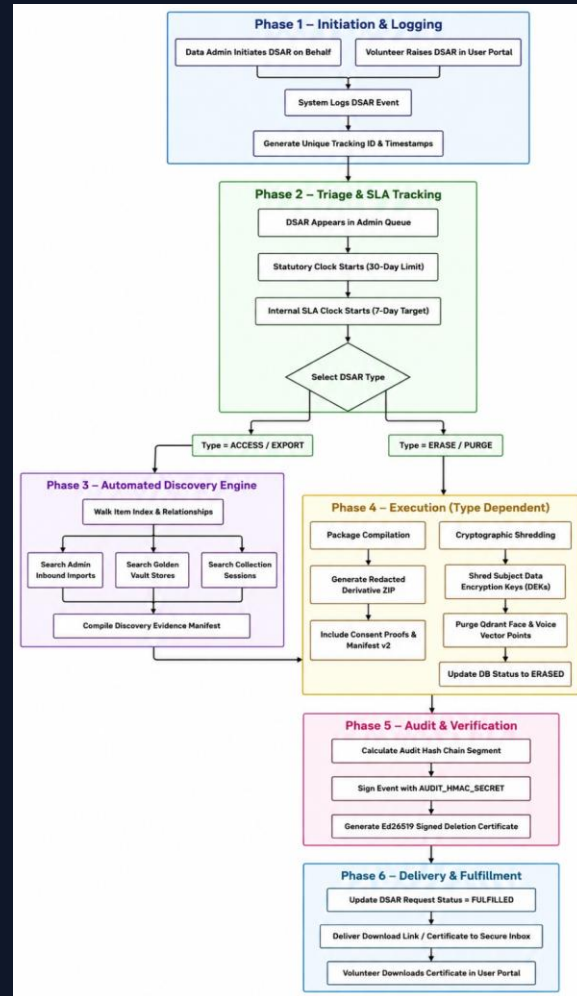
Queue health for the BullMQ workers, the data-lineage graph per person, storage-integrity and orphan-reaper sweeps.

DSAR execution

Discovery workspace, purge or export, evidence vault. Covered on the DSAR architecture slide.

DSAR lifecycle as a flowchart

The same six phases as the architecture slide, drawn end to end with the access and erase branches.



Two branches, one certificate

ACCESS compiles a redacted package with consent proofs and manifest; ERASE shreds the subject key, purges vectors and flips status to ERASED. Both end in a signed audit segment.

Clocks start at triage

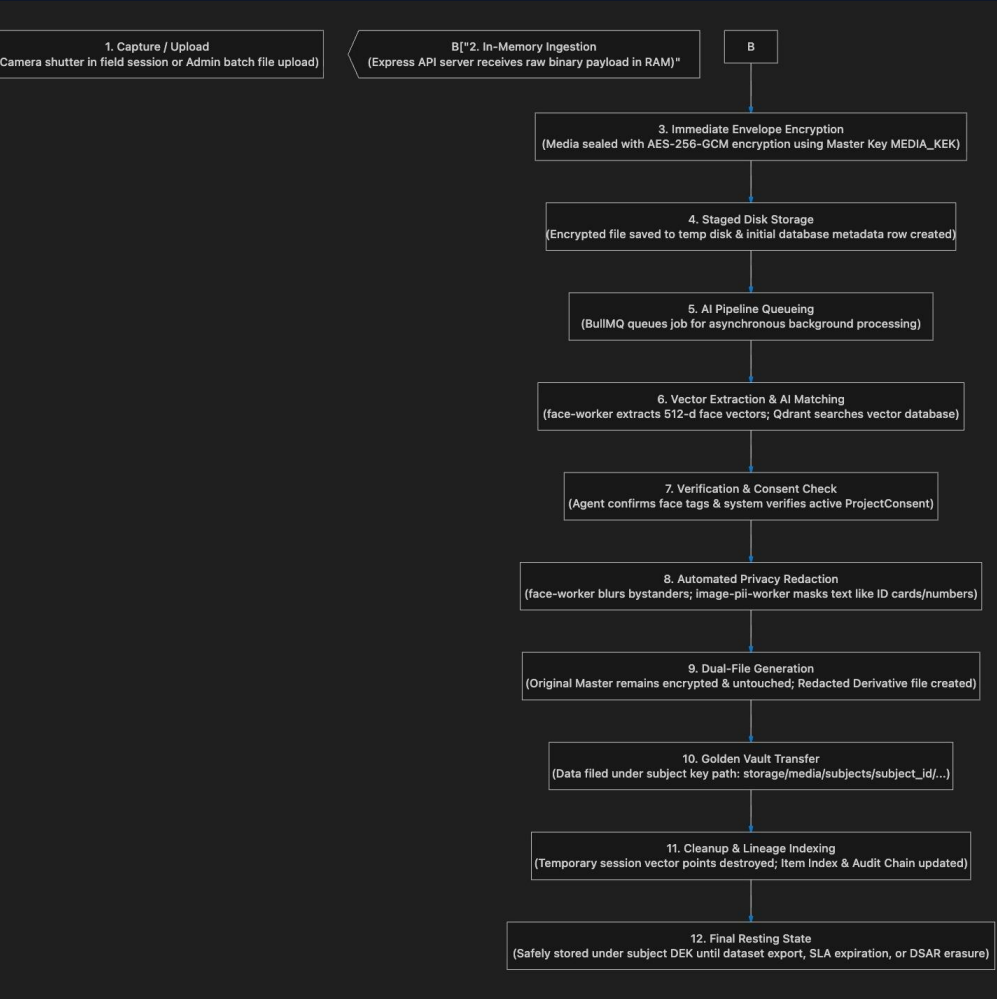
Statutory 30 days and internal 7 days, tracked on the SLA board.

Delivery is pull, not push

The principal downloads the certificate or package from the secure inbox in their own portal.

Capture to storage in twelve steps

The numbered version of the architecture slide: what happens to one frame, in order.



Sealed before it is stored (steps 1-4)

Raw bytes arrive in RAM, are envelope-encrypted with AES-256-GCM under MEDIA_KEK, and only then hit staged disk with a metadata row.

Processed without human eyes (steps 5-8)

BullMQ queues the job; face-worker extracts vectors, Qdrant matches, the agent confirms tags, the backend checks consent, then blur and PII masking run.

Two files, one resting place (steps 9-12)

Original master stays sealed; the redacted derivative is what leaves. Filed under the subject key path, lineage indexed, temp vectors destroyed. Held until export, retention expiry or erasure.

The whole stack on one page

Two React SPAs, one Node.js/Express API with seven queue workers, five Python FastAPI microservices, three infrastructure services.

Frontends

Framework	React 19, React Router 7, Vite 8
Styling	Tailwind CSS 4, tailwind-merge, PostCSS
UI	lucide-react icons, qrcode.react for session QR
In-browser ML	@mediapipe/tasks-vision face-capture guidance
Quality	oxlint; Vitest + Testing Library + jsdom
Ports	data principal :5173 · admin :5180

Backend

Runtime	Node.js (ESM), Express 4, Prisma 5 on PostgreSQL 16 (~60 models)
Queues	BullMQ 5 on Redis 7: recognition, redaction, purge, item-action, export, reaper, retention
Vectors	Qdrant v1.12 face and voice galleries
Auth	JWT, bcrypt, refresh cookies, OTP; five admin roles; helmet, cors, rate limiting, zod
Crypto	AES-256-GCM envelope (MEDIA_KEK > HKDF per-subject DEK); Ed25519 signing; SHA-256
Media	sharp (redaction, thumbnails, EXIF/XMP stamps), multer, streamed ZIP; 215 node --test tests

AI core (5 FastAPI services)

face :8001	InsightFace buffalo_I (SCRFD + ArcFace), onnxruntime, Pillow
image-PIL :8002	RapidOCR-ONNX + Presidio with Indian-identifier recognizers
audio :8003	faster-whisper, pyannote-audio 3.1, SpeechBrain ECAPA, Presidio, torch
text :8004	Presidio Analyzer + Anonymizer, spaCy, Streamlit demo, OpenAI SDK (demo only)
video :8005	InsightFace buffalo_I (shared volume), opencv-headless, IoU tracker
Common	Pydantic v2, uvicorn, Python 3.10-3.12, uv

Infrastructure and verification

Containers	Docker Compose: dev stack with localdb / audio / video profiles; production compose
Edge	Caddy 2 for TLS termination and static portal serving
Orchestration	concurrently starts 10 processes; setup-env.mjs mints per-machine secrets
UI checks	Headless Chrome over raw CDP: route health per role, signup flow, capture-to-export flow
Proof scripts	verify-export.js, verify-dsar.js, inspect-photo-provenance.js, preflight.js
Compliance	DPDP Act: consent, rights requests, signed certificates, retention, breach records, audit and access logs, DPIA

Patentability: five candidate inventions in what we built

Assessment by the team, not legal advice. 'Strength' is our estimate of distance from the closest prior art; the IP team's search decides.

Candidate invention	What PRISM does	Closest prior art	Where the novelty sits	Strength
1. Consent-keyed cryptographic erasure across multimodal derivatives	One HKDF-derived key per data principal seals every original, derivative, embedding and cache. Erasure destroys that key, purges vector-DB points, tombstones the item index and issues an Ed25519 certificate enumerating every location.	Crypto-shredding per user (well known); GDPR erasure tooling; certificate-of-destruction services.	Key scope bound to the consent record; shred extended to derived artefacts (per-person renders, video 'detected' derivative, Qdrant points); completeness proven by enumeration, not assertion.	High
2. Time-domain fail-closed video redaction from a consent-derived box schedule	Strided detection, IoU tracking, sparse per-track embedding. Backend turns the consent matrix into a blur schedule; the worker executes it with tracks that coast (HOLD_SEC), boxes dilated and held past track ends, partial encodes deleted.	Automatic face blurring in video (YouTube, Google, Brighter AI); person tracking for redaction.	Redaction driven by per-identity consent state rather than 'blur all faces'; explicit fail-closed rules in the time axis; decision (backend) separated from execution (stateless worker).	High
3. Detect / Decide / Redact architecture with consent-blind AI workers	Five stateless modality workers report findings and execute rectangle, interval or span lists. Only one component reads consent. Workers hold no database and no memory between calls.	Microservice ML pipelines; privacy-by-design architectures; policy decision / enforcement point separation (XACML).	PDP/PEP separation applied to biometric redaction so an ML fault cannot expose an unconsented person, with one uniform contract across image, video, audio and text.	Medium: strong as a system claim, weak alone
4. Consent-bound provenance stamps on redacted exports	Every exported image carries an Ed25519-signed stamp in EXIF and XMP naming project, session, consent record and export-scoped pseudonyms. A photo found alone still proves lawful origin without revealing a name.	C2PA / Content Credentials; watermarking; signed manifests.	Signing the consent record, not just authorship; pseudonyms scoped per export so two exports cannot be joined; the mapping file inside the archive is the only key.	Medium
5. Speaker-identity consent muting with ephemeral per-session voice galleries	Diarize, transcribe, match each speaker turn against enrolled ECAPA voice prints, mute turns of anyone without consent plus spoken PII, then destroy the session gallery at finalize.	Speaker diarization; voice-based redaction in call centres; PII masking in transcripts.	Per-turn consent decision keyed to enrolment, combined with a gallery lifetime bound to the session: data minimisation as a mechanism, not a policy.	Medium

Weaker as stand-alone claims, useful as dependent claims: the principal-confirmed erasure gate, IMPORT_UNVERIFIED lawful-basis tagging on inbound files, policy-version freezing at approval, the nullable-session completeness rule in discovery.

Patentability: the legal test, the drafting route, and timing

India, where Samsung R&D Institute Bangalore would file first, has a specific bar for software. The claims have to be written for it.

The Indian test: Section 3(k), Patents Act 1970

'A mathematical or business method or a computer programme per se or algorithms' is not an invention.

Not fatal for software. The 2017 CRI guidelines and Ferid Allani v Union of India (Delhi HC, 2019) let claims through when they show a technical effect or technical contribution beyond ordinary program execution.

Our technical effects: irreversible destruction proven by key erasure; a video file that cannot expose a face for a single frame; a redaction pipeline that cannot leak through a failed worker.

How to draft so it passes

Claim the system and the method, not the software: 'a data processing system comprising a key store, a plurality of stateless redaction workers, a consent matrix...'

Lead with the technical problem: frame-level re-identification in redacted video, incomplete erasure of derived artefacts, an ML fault exposing unconsented persons.

Keep the DPDP purpose in the description and out of the claims. Compliance is a business benefit; the examiner scores the mechanism.

Candidates 1 and 2 are the strongest independent claims. 3, 4 and 5 work as dependent claims or a second filing.

Jurisdictions and the cost of waiting

India: no general grace period. A public disclosure (paper, public demo, open repository) before filing destroys novelty. Section 31 covers only exhibitions and learned-society papers, for 12 months.

USA: 12-month grace after the inventor's own disclosure (35 USC 102(b)(1)). Korea: 12 months. EPO: none.

Practical rule: file an Indian provisional before anything leaves the mentors' review. Internal review under NDA is not a disclosure.

1 Invention disclosure

One IDF per candidate through the SRIB IP portal. Inventors: everyone who contributed to the claimed mechanism, not the whole team.

2 Prior-art search

Terms: cryptographic erasure per data subject, consent-driven video redaction, face-track blur schedule, signed deletion certificate, provenance-signed pseudonymous export.

3 Evidence pack

Commit history and dated design documents (DPIA, handoff notes, data-flow document) already fix conception dates. Export them with hashes.

4 Provisional filing

An Indian provisional secures a priority date for 12 months while the complete specification is written; a PCT application within that year keeps US and KR open.

5 Publish after filing

The monthly review deck, the model report and any paper go out only once the priority date exists.

Glossary: platform acronyms and DPDP Act vocabulary

Left: what our acronyms mean. Middle: terms that match the Digital Personal Data Protection Act, 2023. Right: terms in our UI that do not, and what the Act says instead.

Platform acronyms	DPDP Act 2023 terms we use correctly	Terms we use that are not DPDP terms
DSAR Data Subject Access Request: our name for any rights request DPO Data Protection Officer DPIA Data Protection Impact Assessment SLA Service Level Agreement: 7-day internal, 30-day statutory PII Personally Identifiable Information (US/NIST term) OCR / NER Optical Character Recognition / Named Entity Recognition KEK / DEK Key Encryption Key / per-subject Data Encryption Key HKDF Derives each subject's DEK from the master KEK AES-256-GCM Authenticated encryption for every stored blob and vector Ed25519 Signatures on certificates, exports and image provenance HMAC Keyed hash chaining the audit log SHA-256 Content hash recorded before a file is destroyed JWT / RBAC / OTP Session token / role-based access / one-time passcode SCRFD / ArcFace InsightFace face detector / 512-d face embedding ECAPA-TDNN SpeechBrain 192-d voice embedding BullMQ Redis-backed job queue for the seven backend workers Qdrant Vector database for session face and voice galleries EXIF / XMP Image metadata blocks carrying the provenance stamp QR / TTL / CDP Invite code / retention time-to-live / Chrome DevTools Protocol	Data Principal §2(j) the individual. Used in the user portal and backend. Data Fiduciary §2(i) Samsung, who decides purpose and means. Certificate issuer. Data Processor §2(k) the AI workers processing on the fiduciary's behalf. Data Protection Officer §10(2)(a) mandatory for a Significant Data Fiduciary. Our DPO role. Notice §5 what the consent template renders, in the principal's language. Consent / withdrawal §6 free, specific, informed, unambiguous; withdrawal as easy as giving it. Right to access §11 the My Data summary and the ACCESS request. Correction and erasure §12(1) CORRECT and §12(3) ERASE requests. Grievance redressal §13 GRIEVANCE request; §8(10) mechanism; contact on every notice. Nominate §14 NOMINATION request. Personal data breach §2(u), §8(6) our breach records and runbook. Purpose limitation §4, §6 the DPO approval gate and frozen policy version. Significant Data Fiduciary §10 the category that makes a DPO and a DPIA mandatory. Data Protection Board §18 the regulator. Not yet named in our notice: §5(1)(c) requires it.	Consent Manager In the Act (§2(g), §6(7)-(9)) a separate entity registered with the Board, acting for the principal. Our label 'Consent Manager v6.21' is a misuse. Say 'Consent Hub'. Data Subject / Subject GDPR term, used across the admin portal (Subject Verification, 'data subject request'). Act says Data Principal. DSAR GDPR acronym. The Act has no acronym and we also use it for erasure, grievance and nomination. Say 'rights request'. PII US/NIST term (47 UI uses, PiiStatus). Act says personal data §2(t). Sensitive personal data No such category in the 2023 Act (dropped from the 2019 bill). Data Owner Internal role name. The Act avoids ownership language for personal data. 'Project Owner' is safer. Data Admin, Collection Agent, Super Admin, Purge, Handoff Internal operational names. No DPDP meaning either way; fine to keep. <i>Fix is display strings only: enum values (AdminRole, DsarType, PiiStatus) can stay, so migration risk is zero.</i>